

Bezbednosna Revizija i Očvršćavanje Sistema

Sergej Mika SV24/2022

2. jun 2026.

1 Uvod i Arhitektura Modula

Cilj ovog modula je prikupljanje osnovnih sistemskih informacija i identifikacija potencijalnih bezbednosnih propusta na nivou samog operativnog sistema, kernela i vremenske sinhronizacije.

Modul implementira *Living Off the Land* (LOTL) pristup, što znači da se oslanja isključivo na predefinisane i legitimne sistemske alate i komande koje su već dostupne na operativnom sistemu, eliminišući potrebu za instalacijom eksternih alata.

2 Implementirani Bash Kod

U nastavku je prikazan isečak koda koji implementira funkciju unutar glavne skripte:

```
1  system_review() {
2      echo -e "\n--- SYSTEM REVIEW ---"
3
4      echo "[OS Version]"
5      cat /etc/os-release 2>/dev/null
6
7      echo -e "\n[Kernel]"
8      uname -a
9
10     echo -e "\n[Uptime]"
11     uptime
12
13     echo -e "\n[Hostname]"
14     hostname
15
16     echo -e "\n[Timezone]"
17     cat /etc/timezone 2>/dev/null
18
19     echo -e "\n[NTP process]"
20     ps -ef | grep -E "ntp|chrony|timesyncd" | grep -v grep
21 }
22
```

Listing 1: Implementacija funkcije system_review()

3 Detaljna Analiza Provera i Bezbednosnih Rizika

U ovoj sekciji je za svaku izvršenu komandu detaljno objašnjena njena funkcionalnost, kao i bezbednosni rizik koji ona pomaže da se identifikuje.

3.1 Provera verzije operativnog sistema (`cat /etc/os-release`)

- **Opis funkcionalnosti:** Komanda čita sadržaj fajla `/etc/os-release` koji sadrži podatke o nazivu distribucije, verziji i razvojnom ciklusu operativnog sistema (npr. Debian 11, Ubuntu 22.04 LTS).
- **Bezbednosni rizik:** Korišćenje zastarele ili nepodržane (*End-of-Life* - *EOL*) verzije operativnog sistema znači da sistem više ne prima bezbednosne zakrpe (patches). Napadači mogu iskoristiti javno dostupne propuste (CVE) za preuzimanje kontrole nad serverom.

3.2 Provera verzije kernela (`uname -a`)

- **Opis funkcionalnosti:** Prikazuje detaljne informacije o sistemskoj arhitekturi i verziji Linux kernela koji je trenutno učitao u memoriju.
- **Bezbednosni rizik:** Starije verzije kernela često sadrže kritične bezbednosne propuste koji omogućavaju lokalnu eskalaciju privilegija (engl. *Local Privilege Escalation* - *LPE*), gde običan korisnik sa niskim pravima može postati `root`.

3.3 Provera neprekidnog rada sistema (`uptime`)

- **Opis funkcionalnosti:** Prikazuje koliko dugo server radi od poslednjeg restarta, broj trenutno ulogovanih korisnika i opterećenje sistema (*load average*).
- **Bezbednosni rizik:** Ako je vrednost `uptime`-a veoma velika (npr. nekoliko stotina dana), to je jasan indikator da sistem nije restartovan dug vremenski period. Čak i ako administrator redovno pokreće ažuriranje paketa, mnoge kritične zakrpe kernela ne stupaju na snagu sve dok se sistem potpuno ne restartuje.

3.4 Provera imena hosta (`hostname`)

- **Opis funkcionalnosti:** Ispisuje mrežno ime mašine (`hostname`).
- **Bezbednosni rizik:** Ime hosta ne predstavlja direktan tehnički propust, ali loša konvencija imenovanja napadaču daje važne informacije tokom faze izviđanja, olakšavajući mu mapiranje mreže i identifikaciju kritičnih meta.

3.5 Analiza vremenske zone i sinhronizacije (`/etc/timezone` i `ps`)

- **Opis funkcionalnosti:** Proverava konfigurisanu vremensku zonu i pretražuje aktivne procese u potrazi za servisima koji upravljaju sinhronizacijom vremena (`ntpd`, `chronyd`, `systemd-timesyncd`).

- **Bezbednosni rizik:** Ako serveri u produkcionom okruženju nemaju sinhronizovano vreme ili koriste lokalne vremenske zone umesto koordinisanog univerzalnog vremena (**UTC**), dolazi do desinhronizacije logova. U slučaju bezbednosnog incidenta, forenzička analiza i korelacija logova sa različitih servera (npr. veb servera i baze podataka) postaje ekstremno teška ili nemoguća.

4 Zaključak i Preporuke za Očvršćavanje

Na osnovu izlaza modula `system_review()`, administratorima se preporučuju sledeće mere očvršćavanja (*hardening*):

1. Migracija na isključivo LTS (*Long Term Support*) verzije operativnog sistema.
2. Automatizacija primene bezbednosnih zakrpa alatom kao što je `unattended-upgrades`.
3. Planiranje redovnih prozora za održavanje i restartovanje sistema radi primene novih verzija kernela.
4. Obavezno konfigurisanje vremenske zone na **UTC** i pokretanje `systemd-timesyncd` servisa za preciznu sinhronizaciju.